RELATÓRIO TÉCNICO DE VULNERABILIDADES

# CVEs em ferramentas de IA

## Agentes de código, SDKs, assistentes e servidores de LLM — 2026

Foco em outubro de 2026, com o histórico relevante de março a setembro

Data de referência: 23 de outubro de 2026
Produtos: Claude Code / Claude Desktop / Claude Agent SDK, OpenAI Codex, Gemini CLI, GitHub Copilot, Microsoft 365 Copilot, Ollama e LMCache — 9 CVEs e 3 falhas sem CVE
Fontes: avisos dos fabricantes (GitHub Security Advisories), CERT Polska, NVD e pesquisadores

Documento de estudo. Notas e versões vêm dos registros oficiais (NVD / GHSA / CERT); detalhes de exploração vêm dos pesquisadores que reportaram as falhas e estão identificados. Confirme sempre no aviso do fabricante antes de agir.

# Sumário

**1. Sumário executivo** **3**

**2. Por que as falhas de IA são diferentes** **5**

**3. Falhas graves de outubro de 2026** **6**

3.1 CVE-2026-105192 — LMCache: execução remota sem autenticação . . . 6

3.2 CVE-2026-103663 — Ollama: path traversal no /api/pull vira RCE como root . . . 6

3.3 CVE-2026-96620 — Claude Agent SDK: injeção de argumento no resume . . . 7

3.4 SneakPeek — Claude Code Desktop: pré-visualização HTML rouba credenciais . . . 8

**4. Agentes de código: março a setembro** **9**

4.1 Plugin4Shell — plugins adulterados sem clique em quatro agentes . . . 9

4.2 CVE-2026-12537 — Gemini CLI: injeção de comando em CI . . . 9

4.3 CVE-2026-54316 — Claude Code: exfiltração via WebFetch no Hugging Face . . . 10

4.4 AGENTS.md — OpenAI Codex: um agente envenena o próximo . . . 10

4.5 CVE-2026-35603 — agentes no Windows: configuração plantada em ProgramData . . . 11

**5. Servidores de modelos e assistentes corporativos** **12**

5.1 CVE-2026-7482 — Ollama “Bleeding Llama”: vazamento de memória . . . 12

5.2 CVE-2026-24299 — Microsoft 365 Copilot: “Copirate 365” . . . 12

5.3 Relacionada: Windows AI no Patch Tuesday de outubro . . . 13

**6. Padrões que se repetem** **13**

**7. Recomendações práticas** **13**

**Fontes de pesquisa** **15**

# 1. Sumário executivo

Os modelos de linguagem em si (GPT, Claude, Gemini) praticamente nunca recebem CVE: eles rodam como serviço, e falhas no serviço são corrigidas pelo próprio fabricante, sem ação do cliente. As CVEs aparecem no **software ao redor dos modelos**, que roda na máquina ou na infraestrutura de quem usa: agentes de programação (Claude Code, Codex, Gemini CLI, Copilot), SDKs para criar agentes, aplicativos de desktop, integrações de CI/CD e servidores que executam modelos localmente (Ollama, vLLM, LMCache).

Este relatório detalha as falhas críticas e altas de **outubro de 2026** e o histórico relevante de março a setembro, porque várias delas mostram o mesmo padrão e algumas continuam sem correção.

### Principais conclusões

- **Outubro teve quatro falhas graves:** CVE-2026-96620 no Claude Agent SDK para Python (9,2), CVE-2026-103663 no Ollama (9,4, execução de código como root), CVE-2026-105192 no LMCache (9,8) e a SneakPeek no Claude Code Desktop (8,7, ainda sem CVE). Todas já têm correção.
- **Servidores de modelos locais são o risco mais imediato para a infraestrutura:** Ollama e LMCache aceitam conexões **sem autenticação** e, expostos na rede, permitem execução de código. O Ollama já teve outra falha crítica em maio (CVE-2026-7482), com cerca de 300 mil servidores expostos, segundo a Cyera.
- **Nos agentes de código, o alvo é a credencial, não o modelo:** quase todas as falhas terminam em roubo de chaves SSH, tokens de nuvem, `GITHUB_TOKEN` ou chaves de API. O vetor de entrada costuma ser **injeção de prompt** por conteúdo que o agente lê (uma issue, um comentário, um relatório HTML).
- **Ainda há falhas sem correção:** na divulgação da Plugin4Shell (setembro), o GitHub Copilot não tinha correção e o Google informou que não vai corrigir o Gemini CLI antigo. A CVE-2026-35603 (Windows/ProgramData) foi corrigida no Claude Code, mas não no Cursor nem no Codex CLI, segundo a Cymulate.
- **Notas divergentes:** a mesma CVE pode ter nota “Média” do fabricante (CVSS 4.0) e “Crítica” da NVD (CVSS 3.1) — caso da CVE-2026-54316 (6,0 x 9,1). As duas notas estão indicadas.

## Visão geral

| ID | Produto | Tipo | Nota | Divulgada | Corrigido em |
|---|---|---|---|---|---|
| CVE-2026-105192 | LMCache | RCE sem autenticação (pickle) | 9.8 (v3.1) | 07/10 | 0.5.6 |
| CVE-2026-103663 | Ollama | Path traversal → RCE como root | 9.4 (v4) | 08/10 | 0.35.0 |
| CVE-2026-96620 | Claude Agent SDK (Python) | Injeção de argumento → comandos | 9.2 (v4) | 16/10* | 0.2.121 |
| SneakPeek (sem CVE) | Claude Code Desktop | Pré-visualização HTML rouba credenciais | 8.7 (v4) | 16/10 | Desktop 1.30096.1 |
| Plugin4Shell (sem CVE) | Claude Code, Codex, Copilot, Gemini CLI | Plugin adulterado, zero clique | — | 18/09 | Claude Code 2.1.179; Codex 0.146.0; Copilot e Gemini: não |
| CVE-2026-12537 | Gemini CLI / run-gemini-cli | Injeção de comando em CI | 10.0 (v4) | 05/08 | 0.39.1 / 0.1.22 |
| CVE-2026-54316 | Claude Code | Exfiltração via WebFetch (Hugging Face) | 6.0 (v4) / 9.1 (v3.1) | 23/06 | 2.1.163 |
| AGENTS.md (sem CVE) | OpenAI Codex (workflow) | Agente envenena o próximo | — | 05/08 | Mudança de workflow |
| CVE-2026-35603 | Claude Code (e Cursor, Codex CLI, Gemini CLI) | Config em ProgramData → escalada | 7.3 (v3.1) | 17/04 | Claude Code 2.1.75 |
| CVE-2026-7482 | Ollama | Leitura de memória sem autenticação | 9.1 (v3.1) | 04/05 | 0.17.1 |
| CVE-2026-24299 | Microsoft 365 Copilot | Exfiltração via pré-visualização HTML | — | 05/03 | Corrigido no serviço |
| CVE-2026-69923 | Windows AI | Elevação local de privilégio | 7.8 (v3.1) | 13/10 | Patch Tuesday de outubro |

* A CVE-2026-96620 entrou na NVD em 16/10; o aviso do GitHub é de 12/09/2026. Todas as datas são de 2026.

# 2. Por que as falhas de IA são diferentes

As falhas desta lista misturam bugs clássicos (path traversal, desserialização insegura, injeção de argumento) com uma classe nova: o **agente faz o que o conteúdo malicioso manda**. Alguns conceitos ajudam a ler o restante:

| Conceito | Significado |
|---|---|
| Injeção de prompt (indireta) | Instruções escondidas em conteúdo que o modelo lê — uma issue do GitHub, um comentário, um arquivo HTML, um PDF. O modelo não distingue bem “dados” de “ordens” e pode executar o que o atacante escreveu. |
| Agente | Um modelo com ferramentas: ler e escrever arquivos, rodar comandos, acessar a web. Uma injeção de prompt num agente vira ação real na máquina. |
| Aprovação / allowlist | Lista de comandos ou domínios que o agente pode usar sem pedir permissão. Muitos bypasses exploram itens pré-aprovados (ex.: um domínio inteiro liberado). |
| Modo autônomo (“yolo”) | Execução sem confirmação humana — comum em CI. Transforma qualquer injeção em execução de comando. |
| MCP | Model Context Protocol: padrão para conectar ferramentas a agentes. Um servidor MCP “stdio” é um programa que o agente inicia — por isso controlar a configuração MCP é controlar o que executa. |
| Arquivos de instrução | CLAUDE.md, AGENTS.md, .gemini/: o agente os lê automaticamente como orientação. Quem escreve neles comanda o agente. |
| Servidor de inferência | Programa que carrega o modelo e responde por API (Ollama, vLLM, LMCache). Por padrão, vários não têm autenticação — foram pensados para uso local. |
| Pickle | Formato de serialização do Python que executa código ao ser lido. Desserializar pickle vindo da rede equivale a executar código remoto. |

### Por que só alguns casos têm CVE

Fabricantes de serviços em nuvem (ChatGPT, Claude.ai, M365 Copilot) costumam corrigir sem CVE, porque o cliente não precisa instalar nada. Já software que o usuário instala ou empacota (CLIs, SDKs, apps desktop, servidores) recebe CVE, normalmente via GitHub Security Advisories. Por isso falhas graves como a SneakPeek e a Plugin4Shell aparecem aqui sem identificador.

# 3. Falhas graves de outubro de 2026

## 3.1 CVE-2026-105192 — LMCache: execução remota sem autenticação

| CVE-2026-105192 | CRÍTICA · CVSS 3.1 9.8 |
|---|---|
| **Produto** | LMCache — cache de KV (memória de atenção) usado com vLLM e outros servidores de inferência; pacote PyPI `lmcache` |
| **Vetor** | `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` (JFrog) |
| **Fraqueza (CWE)** | CWE-306 (sem autenticação) e CWE-502 (desserialização insegura) |
| **Versões afetadas** | 0.3.9 a 0.5.5, em modo multiprocesso/distribuído (e release candidates da 0.5.6) |
| **Corrigido em** | 0.5.6 (15/10/2026) |
| **Divulgação** | JFrog, 07/10/2026; aviso do LMCache em 13/10 |

### O que identifica

No modo multiprocesso, o LMCache abre um socket ZeroMQ (ROUTER) **sem nenhuma autenticação**. Ao decodificar as mensagens, um tipo específico chega ao `pickle.loads` antes de ter o tipo verificado. Como pickle executa código ao ser lido, uma mensagem forjada executa comandos com o usuário do processo — **root** nas imagens oficiais de contêiner.

Por padrão o socket escuta só em localhost; a exposição acontece quando o operador usa `--host` com um endereço roteável, comum em clusters de GPU.

### Impacto

Controle total do servidor de inferência: acesso aos modelos, aos prompts e respostas dos usuários, às credenciais do ambiente e à rede interna do cluster.

### Correção e mitigação

Atualizar **todos** os workers e servidores juntos para a 0.5.6, que troca pickle por um formato tipado e validado. Até lá, manter o socket em localhost ou numa rede de cluster confiável; firewall reduz, mas não elimina o risco. Se a porta já esteve acessível por redes não confiáveis, tratar o host como comprometido: verificar processos e conexões estranhos, trocar credenciais e reimplantar a partir de imagens limpas.

## 3.2 CVE-2026-103663 — Ollama: path traversal no /api/pull vira RCE como root

| CVE-2026-103663 | CRÍTICA · CVSS 4.0 9.4 |
|---|---|
| **Produto** | Ollama — o servidor mais usado para rodar LLMs localmente |
| **Vetor** | `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H` |
| **Fraqueza (CWE)** | CWE-23 (path traversal relativo) e CWE-913 |
| **Versões afetadas** | 0.34.2 até antes da 0.35.0 |
| **Corrigido em** | 0.35.0 |
| **Divulgação** | CERT Polska (CNA), 08/10/2026 |

### O que identifica

O endpoint `/api/pull` baixa modelos em camadas, cada uma identificada por um **digest** (hash). A função `digestToPath` converte o digest em caminho de arquivo **sem validá-lo**. Um digest com sequências `../` faz o Ollama gravar um arquivo fora da pasta de modelos.

Se o processo puder escrever em `/usr/lib/ollama`, o atacante grava ali uma biblioteca maliciosa, que é carregada e executada como **root** no próximo reinício do serviço. A API do Ollama não tem autenticação.

### Impacto

Execução remota de código como root em qualquer Ollama acessível pela rede — e o impacto atinge outros sistemas (SC/SI/SA altos). A interação exigida (UI:P) é o reinício do serviço, que acontece em atualizações ou reboots.

### Correção e mitigação

Atualizar para 0.35.0 ou posterior. Garantir que o Ollama escute só em `127.0.0.1` (não definir `OLLAMA_HOST=0.0.0.0` sem proteção), colocar um proxy reverso com autenticação na frente quando for preciso acesso remoto e rodar o serviço com usuário sem privilégios, sem escrita em `/usr/lib/ollama`.

```
# Verificar versão e se o Ollama está exposto
ollama -v
ss -ltnp | grep 11434          # 127.0.0.1:11434 = ok; 0.0.0.0:11434 = exposto
curl -s http://SEU_IP:11434/api/version   # de outra máquina: se responder, está acessível
```

## 3.3 CVE-2026-96620 — Claude Agent SDK: injeção de argumento no resume

| CVE-2026-96620 | CRÍTICA · CVSS 4.0 9.2 |
|---|---|
| **Produto** | Claude Agent SDK para Python (`claude-agent-sdk`), da Anthropic — biblioteca para criar agentes sobre o Claude Code |
| **Vetor** | `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N` |
| **Fraqueza (CWE)** | CWE-20, CWE-78 (injeção de comando) e CWE-88 (injeção de argumento) |
| **Versões afetadas** | Anteriores à 0.2.121 |
| **Corrigido em** | 0.2.121 |
| **Divulgação** | GHSA-h4mw-j7qp-8mwm (12/09/2026); NVD em 16/10/2026. Relator via HackerOne: moamenmahmood |

### O que identifica

O SDK inicia o CLI do Claude como subprocesso e repassava a opção `resume` (o ID da sessão a retomar) **sem validar**. Um valor começando com `-` era interpretado como outra opção de linha de comando.

O atacante passa algo como `--mcp-config ...` e define um servidor MCP do tipo stdio — que nada mais é que um comando que o CLI executa ao iniciar. A execução acontece **fora** dos controles de permissão do SDK.

### Impacto

Execução arbitrária de comandos no servidor que hospeda o agente. Só é explorável quando a aplicação usa **entrada não confiável** como ID de sessão — por exemplo, um parâmetro de URL ou campo de API que o usuário final controla.

### Correção e mitigação

Atualizar para 0.2.121. Boa prática independente: validar IDs de sessão (formato UUID) e nunca repassar entrada do usuário diretamente como argumento de processo.

## 3.4 SneakPeek — Claude Code Desktop: pré-visualização HTML rouba credenciais

| SneakPeek | ALTA · CVSS 4.0 8.7 (sem CVE) |
|---|---|
| **Produto** | Claude Code Desktop (aplicativo), painel de pré-visualização |
| **Pesquisador** | Eli Ainhorn — Noma Labs |
| **Linha do tempo** | Relatado em 04/07/2026; patch inicial 24/07 (contornado no mesmo dia); correção final 17/08; divulgado em 16/10/2026 |
| **Corrigido em** | Claude Desktop 1.30096.1 ou posterior |
| **CVE** | Atribuição e GitHub Advisory pendentes na data da divulgação |

### O que identifica

O painel de pré-visualização renderiza arquivos HTML que o Claude lê ou edita. Três falhas juntas permitiram executar JavaScript nele: arquivos pequenos carregavam sem o bloqueio de scripts funcionando, arquivos grandes carregavam sem bloqueio nenhum, e o filtro de requisições não impedia ler arquivos locais.

Um script escondido, por exemplo, num relatório de cobertura de testes de um repositório público rodava quando o desenvolvedor pedia ao Claude para revisar ou editar o arquivo. O primeiro patch bloqueou `fetch()` e `XMLHttpRequest`; a Noma o contornou no mesmo dia usando Web Workers criados a partir de URLs `blob:`.

### Impacto

Leitura e envio silencioso, sem nenhum aviso, de chaves SSH, credenciais de nuvem, de registro de pacotes e do Git, e do token OAuth do Claude. Não há relato de exploração real.

### Correção e mitigação

Atualizar o Claude Desktop. Depois, revisar se credenciais ficam em arquivos de texto em `~/.ssh`, `~/.aws` etc. sem proteção (passphrase, cofres) e considerar trocá-las se repositórios não confiáveis foram abertos no app antes de 17/08.

# 4. Agentes de código: março a setembro

## 4.1 Plugin4Shell — plugins adulterados sem clique em quatro agentes

| Plugin4Shell | SEM NOTA · sem CVE / sem CVSS |
|---|---|
| **Produtos** | Claude Code, OpenAI Codex, GitHub Copilot e Gemini CLI |
| **Pesquisadores** | Or Nevo, Dor Granat e Niv Hoffman |
| **Divulgação** | 18/09/2026 |
| **Correção** | Claude Code 2.1.179 · Codex 0.146.0 · **Copilot: sem correção na divulgação** · **Gemini CLI: o Google não vai corrigir** (versão descontinuada; recomenda migrar) |

### O que identifica

Os agentes instalam plugins apontando para um commit específico (um hash de 40 caracteres), mas não conferem se o código baixado é mesmo aquele commit. O atacante cria no repositório do plugin um **branch com o mesmo nome do hash** e o torna o branch padrão; o Git resolve o nome do branch em vez do commit e instala o código do atacante. No Gemini CLI, algo parecido acontece com um branch chamado `FETCH_HEAD`.

### Impacto

Como vários agentes atualizam plugins automaticamente, o ataque pode ser **zero clique**: o código malicioso roda na máquina do desenvolvedor com acesso ao que o agente acessa.

### Correção e mitigação

Atualizar Claude Code e Codex. No Copilot e no Gemini CLI, limitar plugins a fontes confiáveis, desativar a atualização automática de plugins e migrar do Gemini CLI descontinuado.

## 4.2 CVE-2026-12537 — Gemini CLI: injeção de comando em CI

| CVE-2026-12537 | CRÍTICA · CVSS 4.0 10.0 |
|---|---|
| **Produto** | Gemini CLI e a GitHub Action run-gemini-cli (Google) |
| **Aviso** | GHSA-wpqr-6v78-jr5g |
| **Pesquisa** | Novee Security — Black Hat USA, 05/08/2026 |
| **Corrigido em** | Gemini CLI 0.39.1 · run-gemini-cli 0.1.22 |

### O que identifica

Uma **injeção de comando no lançador do contêiner**, acionada por um arquivo `.gemini/.env` preparado, permitia executar código no host do CI antes de o sandbox iniciar. Separadamente, a lista de ferramentas permitidas não era aplicada em tempo de execução: com `--yolo`, todo comando pedido pelo modelo era aprovado.

O ataque partia de uma simples issue no GitHub, aberta por uma conta sem nenhum privilégio no repositório. Os segredos do processo pai continuavam acessíveis via `/proc`.

### Impacto

Execução de código no runner do CI, roubo de segredos (tokens do GitHub, chaves de API) e possível tomada do repositório.

### Correção e mitigação

Atualizar. Auditar workflows que usuários externos possam disparar (issues, comentários, PRs de forks) e não usar modo autônomo com segredos disponíveis.

## 4.3 CVE-2026-54316 — Claude Code: exfiltração via WebFetch no Hugging Face

| CVE-2026-54316 | MÉDIA · CVSS 4.0 6.0 / NVD 3.1: 9.1 |
|---|---|
| **Produto** | Claude Code (Anthropic) |
| **Aviso** | GHSA-fg94-h982-f3mm |
| **Versões afetadas** | 0.2.54 até antes da 2.1.163 |
| **Corrigido em** | 2.1.163 |
| **Nota** | Anthropic: Moderada, CVSS 4.0 6,0. NVD: CVSS 3.1 9,1 (Crítica). As escalas não são diretamente comparáveis. |

### O que identifica

O domínio `huggingface.co` estava **pré-aprovado** para a ferramenta WebFetch, então qualquer URL dele era acessada sem pedir permissão, mesmo com `--allowedTools`. Com uma injeção de prompt, o agente fazia requisições a arquivos do Hugging Face cujos nomes codificavam dados; o atacante lia o resultado pelo **contador público de downloads**, vazando uma chave de API caractere por caractere.

Na mesma pesquisa (Novee, agosto), uma segunda cadeia sem CVE mostrou que o validador de comandos removia o texto entre aspas simples antes de checar, deixando passar um payload em `git push --receive-pack` no GitHub Action.

### Impacto

Vazamento de segredos (ex.: `ANTHROPIC_API_KEY`, `GITHUB_TOKEN`) a partir de conteúdo não confiável lido pelo agente, especialmente em CI.

### Correção e mitigação

Atualizar para 2.1.163 ou posterior. Restringir domínios do WebFetch e não dar segredos a agentes que processam conteúdo de terceiros.

## 4.4 AGENTS.md — OpenAI Codex: um agente envenena o próximo

| AGENTS.md | SEM NOTA · sem CVE |
|---|---|
| **Produto** | Workflow do OpenAI Codex em GitHub Actions (duas passagens no mesmo job) |
| **Pesquisa** | Novee Security — Black Hat USA, 05/08/2026 |
| **Correção** | Sem CVE. A OpenAI separou as passagens em jobs diferentes, com drop-sudo e sandbox somente leitura, e passou a recomendar tratar arquivos de instrução como entrada não confiável |

### O que identifica

A primeira passagem do Codex lia o conteúdo não confiável da issue com permissão de escrita numa área compartilhada e podia criar um `AGENTS.md`. A segunda passagem, com mais privilégios, carregava esse arquivo como instruções. Nenhuma fuga de sandbox foi necessária — a OpenAI considera que o sandbox se comportou como documentado.

### Impacto

O atacante comanda o agente privilegiado por meio de um arquivo de instruções escrito pelo agente sem privilégios.

### Correção e mitigação

Rodar agentes em jobs separados das etapas privilegiadas, como último passo do job, e tratar `AGENTS.md`/`CLAUDE.md` e demais arquivos do repositório como dados não confiáveis.

## 4.5 CVE-2026-35603 — agentes no Windows: configuração plantada em ProgramData

| CVE-2026-35603 | ALTA · CVSS 3.1 7.3 (NVD) |
|---|---|
| **Produtos** | Claude Code (CVE), Cursor, OpenAI Codex CLI e Google Gemini CLI — no Windows |
| **Aviso** | GHSA-5cwg-9f6j-9jvx (Claude Code); pesquisa da Cymulate |
| **Vetor** | `CVSS:3.1/AV:L/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H`; GitHub (CVSS 4.0): 5,4 |
| **Fraqueza (CWE)** | CWE-426: caminho de busca não confiável |
| **Corrigido em** | Claude Code 2.1.75 (configurações gerenciadas movidas para Program Files). Segundo a Cymulate: Cursor e Codex CLI sem correção; Gemini CLI tratado como atualização de documentação |

### O que identifica

As ferramentas carregavam configurações de `C:\ProgramData\`, pasta onde qualquer usuário comum pode criar subpastas. Um usuário sem privilégios cria a pasta antes e coloca uma configuração com um **hook** (comando executado em eventos). No Codex CLI, a configuração também podia liberar o sandbox e desligar as confirmações.

### Impacto

Em máquinas compartilhadas (servidores de desenvolvimento, VDI, laboratórios), o comando roda na sessão de qualquer outro usuário que abrir a ferramenta — inclusive administradores: escalada de privilégio e persistência.

### Correção e mitigação

Atualizar o Claude Code. Para as demais ferramentas: criar previamente as pastas em `C:\ProgramData` com permissão só para administradores e monitorar a criação de arquivos nelas.

# 5. Servidores de modelos e assistentes corporativos

## 5.1 CVE-2026-7482 — Ollama “Bleeding Llama”: vazamento de memória

| CVE-2026-7482 | CRÍTICA · CVSS 3.1 9.1 / 4.0 8.8 |
|---|---|
| **Produto** | Ollama |
| **Vetor** | `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H` |
| **Fraqueza (CWE)** | CWE-125: leitura fora dos limites |
| **Versões afetadas** | Anteriores à 0.17.1 |
| **Corrigido em** | 0.17.1 (PR #14406) |
| **Divulgação** | Cyera, maio de 2026; SSVC da CISA: automatizável, impacto técnico total |

### O que identifica

Um arquivo de modelo GGUF preparado, enviado ao `/api/create`, declara tensores com tamanhos e posições além do fim do arquivo. Na quantização, o Ollama lê além do buffer. O atacante grava a memória vazada num “modelo” e o envia para fora com `/api/push` — três chamadas de API, sem autenticação.

### Impacto

A memória vazada pode conter prompts e conversas de outros usuários, prompts de sistema e variáveis de ambiente com chaves de API. A Cyera estimou cerca de 300 mil servidores expostos na internet.

### Correção e mitigação

Atualizar (a versão 0.35.0 corrige também a CVE de outubro). Não expor a porta 11434; usar proxy com autenticação.

## 5.2 CVE-2026-24299 — Microsoft 365 Copilot: “Copirate 365”

| CVE-2026-24299 | SEM NOTA · corrigido no serviço |
|---|---|
| **Produto** | Microsoft 365 Copilot (Word desktop e online, Excel) e Copilot de consumo |
| **Pesquisador** | Johann Rehberger (Embrace The Red) — DEF CON Singapura, maio de 2026 |
| **Correção** | CVE-2026-24299 corrigida em 05/03/2026; as falhas de memória foram corrigidas em dezembro de 2025. Nenhuma ação do cliente |

### O que identifica

A pré-visualização HTML do Copilot permitia que CSS (`background-image`, `@font-face`) fizesse requisições ao servidor do atacante carregando dados na URL. Com injeção de prompt num documento, o Copilot podia abrir a pré-visualização sozinho — zero clique.

Na mesma pesquisa: envenenamento da **memória** do Copilot (a ferramenta `record_memory` criava e apagava “lembranças” falsas, sem registro no Purview) e “SpAIware”, uma memória persistente que vazava senhas em conversas futuras.

### Impacto

Vazamento de dados corporativos que o Copilot acessa (e-mails, documentos) a partir de um único documento malicioso compartilhado.

### Correção e mitigação

Já corrigido pela Microsoft. Para o suporte: revisar as políticas de memória do Copilot e os rótulos de sensibilidade (Purview) e orientar usuários sobre documentos externos.

## 5.3 Relacionada: Windows AI no Patch Tuesday de outubro

O Patch Tuesday de 13/10/2026 trouxe a **CVE-2026-69923** (Windows AI, elevação local de privilégio, CVSS 7,8, “Exploitation More Likely” segundo a Tenable). Ela é corrigida pela atualização cumulativa de outubro do Windows — detalhes no relatório da Microsoft entregue anteriormente.

# 6. Padrões que se repetem

- **Sem autenticação por padrão:** Ollama e LMCache foram feitos para uso local; o risco aparece quando alguém os expõe (`0.0.0.0`, `--host`) para a equipe ou o cluster.
- **Desserialização e caminhos de arquivo:** bugs antigos (pickle, path traversal, leitura fora do buffer) em software novo, escrito às pressas para acompanhar o mercado de IA.
- **Injeção de prompt como porta de entrada:** em agentes, quem escreve o conteúdo que o agente lê (issue, comentário, HTML, documento) controla o agente. A defesa precisa estar no que o agente **pode fazer**, não em filtrar o texto.
- **A credencial é o prêmio:** SSH, nuvem, `GITHUB_TOKEN`, chaves de API. Agentes costumam rodar com todas as credenciais do desenvolvedor ou do CI.
- **Correções incompletas e silêncio:** a SneakPeek foi contornada no mesmo dia do primeiro patch; Copilot, Cursor e Gemini CLI deixaram falhas sem correção na divulgação.

# 7. Recomendações práticas

### Para o suporte técnico e a infraestrutura

- Inventariar ferramentas de IA instaladas: Ollama, LM Studio, vLLM/LMCache, Claude Code/Desktop, Codex, Gemini CLI, Cursor, extensões do Copilot. Muitas são instaladas pelos próprios desenvolvedores, fora do controle da TI.
- Atualizar: Ollama ≥ 0.35.0, LMCache ≥ 0.5.6, `claude-agent-sdk` ≥ 0.2.121, Claude Desktop ≥ 1.30096.1, Claude Code ≥ 2.1.179, Codex ≥ 0.146.0, Gemini CLI ≥ 0.39.1.
- Procurar servidores de modelos expostos: porta 11434 (Ollama), portas do vLLM/LMCache. Eles devem escutar só em localhost ou ficar atrás de proxy com autenticação.
- Executar serviços de IA com usuário sem privilégios (nunca root) e em contêiner sem acesso ao restante da rede.
- Em máquinas Windows compartilhadas, proteger `C:\ProgramData` (CVE-2026-35603).

### Para quem usa agentes de código

- Não rodar agentes em modo autônomo em repositórios ou arquivos de origem desconhecida.
- Em CI, não disponibilizar segredos para jobs de agente disparados por issues, comentários ou PRs de forks; dar ao token apenas as permissões mínimas.
- Tratar arquivos de instrução (CLAUDE.md, AGENTS.md, .gemini/) e relatórios HTML de terceiros como não confiáveis.
- Guardar credenciais em cofres ou agentes (ssh-agent com passphrase, SSO de nuvem com sessões curtas), e não em arquivos de texto que qualquer processo lê.

### Detecção (Blue Team)

- Conexões de entrada em portas de servidores de IA vindas de fora da rede esperada; downloads de modelos de registries desconhecidos via `/api/pull`.
- Processos filhos inesperados de `ollama`, `python` (LMCache/vLLM), `claude`, `codex` e `gemini`.

- Requisições de saída de agentes para domínios incomuns, ou muitas requisições pequenas ao mesmo domínio (exfiltração gota a gota).
- Uso de tokens e chaves de API de agentes a partir de IPs ou horários anormais.

# Fontes de pesquisa

Consultadas em 23/10/2026. Os avisos dos fabricantes, do CERT Polska e os registros da NVD são as fontes primárias para notas e versões; descrições de exploração vêm dos pesquisadores citados.

## Avisos oficiais e registros de CVE


[1] GitHub Advisory GHSA-h4mw-j7qp-8mwm — Claude Agent SDK (Anthropic)
https://github.com/anthropics/claude-agent-sdk-python/security/advisories/GHSA-h4mw-j7qp-8mwm

[2] NVD — CVE-2026-96620
https://nvd.nist.gov/vuln/detail/CVE-2026-96620

[3] CERT Polska — CVE-2026-103663 (Ollama)
https://cert.pl/en/posts/2026/10/CVE-2026-103663/

[4] NVD — CVE-2026-103663
https://nvd.nist.gov/vuln/detail/CVE-2026-103663

[5] NVD — CVE-2026-105192 (LMCache)
https://nvd.nist.gov/vuln/detail/CVE-2026-105192

[6] NVD — CVE-2026-54316 (Claude Code)
https://nvd.nist.gov/vuln/detail/CVE-2026-54316

[7] GitHub Advisory GHSA-fg94-h982-f3mm — Claude Code
https://github.com/anthropics/claude-code/security/advisories/GHSA-fg94-h982-f3mm

[8] NVD — CVE-2026-35603 (Claude Code / Windows)
https://nvd.nist.gov/vuln/detail/CVE-2026-35603

[9] GitHub Advisory GHSA-5cwg-9f6j-9jvx — Claude Code
https://github.com/anthropics/claude-code/security/advisories/GHSA-5cwg-9f6j-9jvx

[10] NVD — CVE-2026-7482 (Ollama)
https://nvd.nist.gov/vuln/detail/CVE-2026-7482

[11] Anthropic Frontier Red Team — painel de divulgação coordenada
https://red.anthropic.com/2026/cvd/


## Pesquisadores e imprensa especializada


[12] The Hacker News — Critical LMCache Flaw Lets Unauthenticated Attackers Run Code Remotely
https://thehackernews.com/2026/10/unpatched-critical-lmcache-flaw-lets.html

[13] Hackread — Claude Code Desktop Flaw Let Malicious HTML Steal Developer Credentials
https://hackread.com/claude-code-desktop-flaw-html-steal-credentials/

[14] Dark Reading — Anthropic 'SneakPeek' Flaw Is a Silent Zero-Click Threat
https://darkreading.com/threat-intelligence/new-anthropic-sneakpeek-silent-zero-click-threat

[15] GBHackers — Plugin4Shell Zero-Click RCE Hits Claude Code, Codex, Copilot and Gemini CLI
https://gbhackers.com/plugin4shell-zero-click-rce/

[16] The Hacker News — Claude Code and Gemini CLI Flaws Let a GitHub Issue Reach CI Workflow Secrets
https://thehackernews.com/2026/08/claude-code-and-gemini-cli-flaws-let.html

[17] GBHackers — Critical Flaws in Claude Code, Gemini CLI, and OpenAI Codex
https://gbhackers.com/critical-flaws-in-claude-code-gemini-cli-and-openai-codex/amp/

[18] Cymulate — CVE-2026-35603: Exploiting Configuration Trust in AI Coding Tools
https://cymulate.com/blog/cve-2026-35603-ai-coding-tools-privilege-escalation/

[19] Cyera — Bleeding Llama: Critical Unauthenticated Memory Leak in Ollama
https://www.cyera.com/research/bleeding-llama-critical-unauthenticated-memory-leak-in-ollama

[20] Embrace The Red — Copirate 365 at DEF CON (CVE-2026-24299)
https://embracethered.com/blog/posts/2026/defcon-talk-copirate-365/

[21] DFIR Lab — Weekly Threat Briefing 12–19/10/2026
https://dfir-lab.ch/intel-briefings/weekly-briefing-2026-10-19

[22] Tenable — Microsoft's October 2026 Patch Tuesday (CVE-2026-69923)
https://www.tenable.com/blog/microsofts-october-2026-patch-tuesday-addresses-1407-cves-cve-2026-96951